

Learning objectives

In this lesson you will learn to:

- Define what is meant by the term 'social engineering'
- Describe some commonly used social engineering tactics (phishing, pretexting, baiting, quid pro quo) used by hackers
- Explain the purpose of an Acceptable Use Policy (AUP) and what it typically includes.

For more information and additional learner activities see Topic 5.3 of the student book.

Social engineering

Social engineering is practised on people, not computers.

Hackers (social engineers) exploit human behaviour, fallibility, and goodwill to gain confidential information.

Examples include:

- phishing
- pretexting (blagging)
- baiting
- quid pro quo

Protecting against social engineering

Social engineering attacks rely on humans making mistakes.

Protecting a system from human error is highly challenging.

One of the best defensive tools organisations can use is an **Acceptable Use Policy (AUP)**.

An AUP is a collection of rules and procedures that employees are required to follow in order to protect their organisation's systems and networks.

Training is often provided to reinforce an AUP's rules.

Acceptable Use Policies (AUPs)

Common rules and procedures contained within most AUPs include:

- limits on access to the internet
- preventing users downloading files or installing software
- preventing users plugging in external drives (USB sticks)
- training users to recognise phishing emails
- multi-factor authentication
- training users not to give out confidential information over the phone
- preventing users from removing files from the premises.

Dealing with risky situations

For each of these situations, describe the potential risks of the action and come up with a rule for an AUP that would prevent the action.

- A user has uploaded an MP3 file downloaded from the internet to a shared drive.
- A user receives a suspicious email which tells them their online shopping account has been compromised. They click the link provided to reset their password.
- An employee finds a USB memory stick in the car park and decides to plug it into their computer to see who it belongs to.
- An employee uses a social media account on their company laptop.

Wrap up: you have learned how to...

- ✓ Define what is meant by the term 'social engineering'.
 - Attacks on systems or networks that manipulate people to trick them into giving away more information than they should.
- ✓ Describe commonly used social engineering tactics used by hackers.
 - Phishing, pretexting, baiting, and quid pro quo.
- ✓ Explain the purpose of an Acceptable Use Policy (AUP) and what it typically includes.
 - AUPs contain rules and procedures that users have to follow to keep an organisation's system and data safe.
 - Common rules include restrictions on hardware and internet access and the use of passwords. User training is often provided.